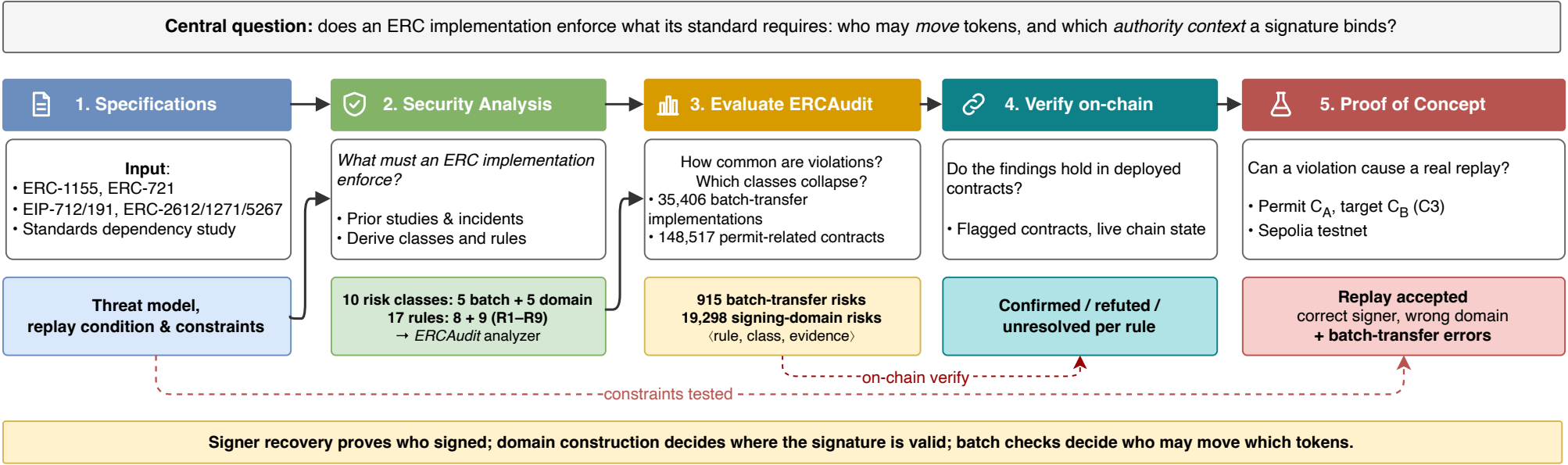

Central question: does an ERC implementation enforce what its standard requires: who may move tokens, and which authority context a signature binds?
1. Specifications
2. Security Analysis
3. Evaluate ERCAudit
4. Verify on-chain
5. Proof of Concept
Input:
• ERC-1155, ERC-721
• EIP-712/191, ERC-2612/1271/5267
• Standards dependency study
What must an ERC implementation enforce?
• Prior studies & incidents
• Derive classes and rules
How common are violations?
Which classes collapse?
• 35,406 batch-transfer implementations
• 148,517 permit-related contracts
Do the findings hold in deployed contracts?
• Flagged contracts, live chain state
Can a violation cause a real replay?
• Permit C_A, target C_B (C3)
• Sepolia testnet
Threat model, replay condition & constraints
10 risk classes: 5 batch + 5 domain
17 rules: 8 + 9 (R1–R9)
→ ERCAudit analyzer
915 batch-transfer risks
19,298 signing-domain risks
⟨rule, class, evidence⟩
Confirmed / refuted / unresolved per rule
Replay accepted
correct signer, wrong domain
+ batch-transfer errors
on-chain verify
constraints tested
Signer recovery proves who signed; domain construction decides where the signature is valid; batch checks decide who may move which tokens.